DOCTOR–PATIENT MEDICAL SERVICES PLATFORM

System Analysis, Software Architecture, Database Design, Security, Performance & UI/UX Specification

Working title
This report uses “Medical Platform” as a neutral working name. The final product/brand name can be inserted later without changing the architecture.

Technology baseline

React • HTML5 • CSS3 • Bootstrap • Figma • PHP Laravel • Node.js • PostgreSQL • Docker • Cloud Deployment

Prepared: August 2026

Table of Contents

1. Executive Summary

2. Product Vision, Business Model and Scope

3. Users, Roles and Access Model

4. Functional Requirements

5. Non-Functional Requirements

6. Matching, Rating and Business Rules

7. Use Cases and User Journeys

8. System Architecture and Technology Stack

9. Database and Domain Design

10. Backend Development Responsibilities

11. Frontend and UI/UX Design

12. Web Page Inventory and Navigation

13. Security, Privacy and Payment Design

14. Performance, Bandwidth, Availability and Capacity Calculations

15. Docker, Cloud Deployment and DevOps

16. Testing and Quality Assurance

17. MVP Delivery Phases and Team Workstreams

18. Assumptions, Risks and Future Enhancements

19. Acceptance Criteria

20. Standards and Reference Baseline

1. Executive Summary

The proposed website is a healthcare mediation platform that connects patients and patient families with verified doctors and clinics. It combines provider discovery and matching, appointment booking, ratings and reviews, payment orchestration, and a longitudinal patient medical-record history that can include visits, treatments, prescriptions, medicines, laboratory tests, diagnostic imaging reports, and uploaded medical documents.

The patient-facing service can remain free of platform subscription fees while revenue is generated primarily through advertising, sponsored placements, and optional business-to-business promotional services. Payment support is still required because patients may need to pay a doctor, clinic, laboratory, imaging center, or other healthcare provider. The safest design is to process such payments through an external certified gateway and keep card data outside the platform.

Clinical safety boundary
The first release should match a stated condition or care need to an appropriate specialty/provider category. It should not diagnose a patient or replace emergency services. Urgent/emergency symptom rules must override ordinary ranking and show a clear emergency-care instruction.

- Every user must register and sign in; privileged roles use stronger verification and MFA.
- Patients may create dependent/family profiles and grant controlled access to their records.
- Doctors and clinics require credential verification before being shown as “Verified”.
- Reviews are tied to completed appointments to reduce fake ratings and abuse.
- Medical history is stored as a chronological, auditable record; amendments are versioned rather than silently overwriting history.
- Raw card details and CVV are never stored by the platform; payment tokens and gateway transaction references are stored instead.
- Advertising is separated from clinical matching and must not expose sensitive medical data to advertisers.

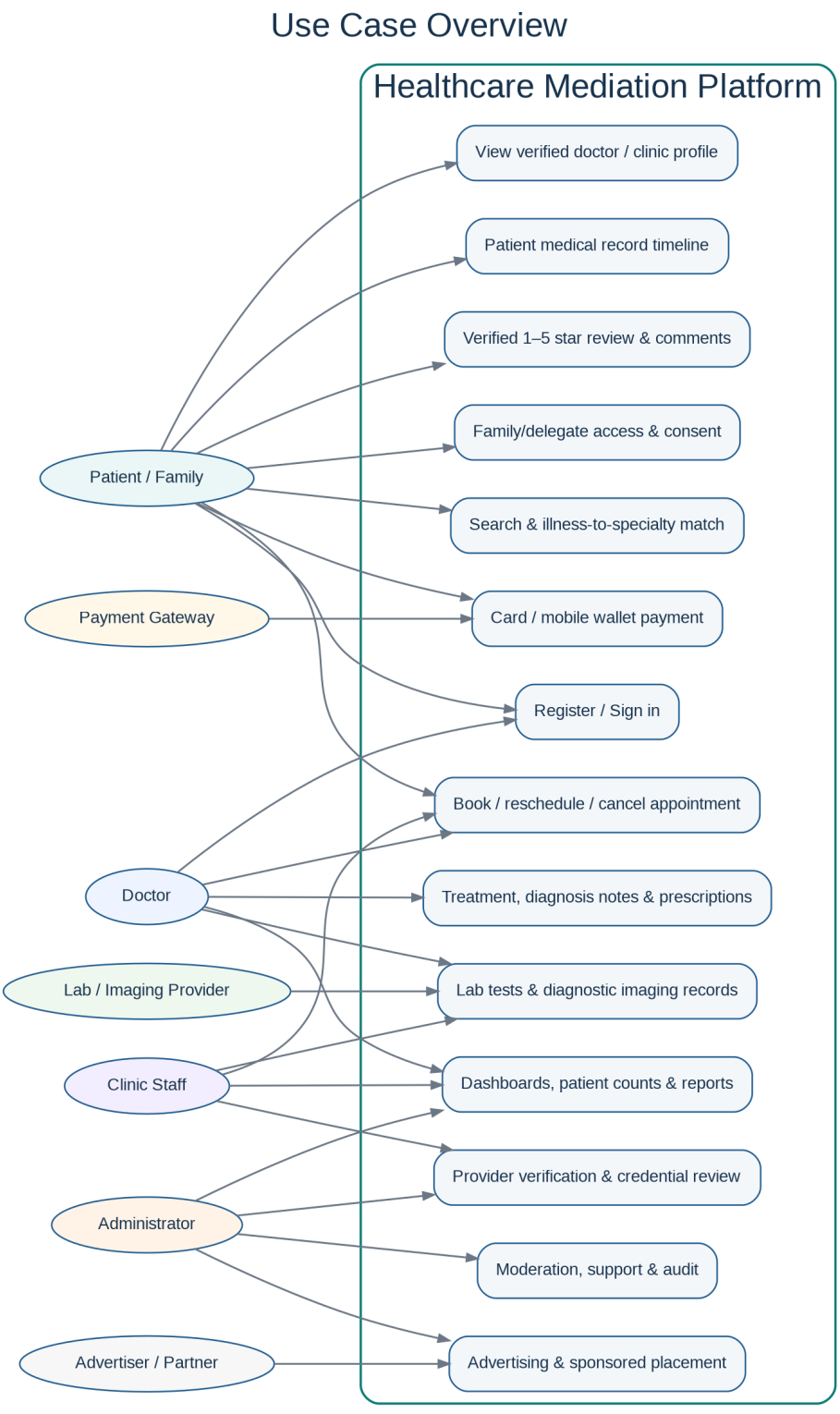


Figure 1 — High-level use cases and external actors.

2. Product Vision, Business Model and Scope

2.1 Product Vision

Create a trusted digital access layer between people seeking care and healthcare providers. The product should help a patient identify the correct specialty, compare verified providers, book care, retain a personal care history, and securely share relevant information with authorized family members and clinicians.

2.2 Business Model

Revenue / Service	Design Approach
Patient platform access	Free registration, search, booking management, record access and review features.
Provider payment flow	Optional payment to provider through card/mobile-wallet gateway; platform service fee may be configured as zero.
Advertising	Display/contextual advertising and clearly labeled sponsored provider placements.
Provider promotion	Optional B2B campaigns, featured profiles or clinic marketing packages; never disguised as clinical ranking.
Future enterprise services	API integrations, employer/insurance programs, advanced clinic analytics, telemedicine or lab/PACS integrations.

2.3 In-Scope MVP

- Public marketing site and provider directory.
- Patient/family, doctor, clinic and administrator registration/login.
- Provider verification workflow and profile management.
- Condition/specialty search and matching with filters.
- Appointment availability, booking, rescheduling, cancellation and reminders.
- Patient medical timeline, encounter records, prescriptions, lab/imaging results and document upload.
- Card/mobile-wallet payment orchestration through third-party gateway.
- 1–5 star verified reviews and comments with moderation.
- Admin backend for users, providers, content, ads, transactions, reports, security logs and system configuration.
- Responsive React web application and Dockerized cloud deployment.

2.4 Out of Scope for Initial MVP

- Autonomous diagnosis, prescribing, triage diagnosis or clinical decision support.
- Insurance claims adjudication and payer integrations unless separately commissioned.
- Full PACS replacement or storage of raw high-volume DICOM studies; MVP should store reports/attachments and integrate with PACS later.
- Pharmacy dispensing/controlled-drug fulfillment.
- Nationwide health-information-exchange interoperability unless regulatory and partner APIs are available.
- In-house storage/processing of raw payment card PAN/CVV data.

3. Users, Roles and Access Model

Role	Primary Permissions
Visitor	Browse public pages, search providers, view public profiles, read approved reviews and marketing content.
Patient	Manage own profile, search/match, book, pay, see personal medical history, upload documents, grant consent, review completed visits.
Family / Delegate	Access only the patient/dependent records and functions explicitly granted through consent/delegation.
Doctor	Manage profile and availability; see authorized booked patients; document encounters; issue prescriptions/orders; review results; view own metrics.
Clinic Staff	Manage clinic profile, doctors, schedules, appointments and operational reports based on assigned staff role.
Clinic Administrator	Manage clinic staff permissions, provider affiliations, schedule templates, billing summaries and clinic-level reporting.
Platform Support	Resolve account/booking issues; limited access to sensitive clinical content; all support access is audited.
Clinical/Provider Verifier	Review doctor/clinic credentials and activate/suspend verification status.
Content / Review Moderator	Moderate public reviews, comments and advertising content without default access to patient clinical history.
Finance Administrator	View gateway transactions, refunds, settlements and reconciliation data; no need for clinical-content access.
Security / Compliance Administrator	Review access logs, security events, consent/audit evidence, retention and incident workflows.
Super Admin	System configuration and emergency operations; use separate privileged account, MFA, just-in-time elevation and enhanced audit logging.
Advertiser / Partner	Submit campaigns and assets; see campaign analytics only; no access to patient records or condition-level private profiles.

3.1 Access-Control Principles

- Deny by default; grant minimum necessary permissions.
- Use role-based access control plus attribute/relationship checks (patient ownership, doctor appointment relationship, clinic membership, consent scope).
- Use PostgreSQL Row-Level Security on sensitive patient-scoped tables as an additional database-level boundary.
- Administrative authority does not automatically imply clinical-record visibility.
- Use a “break-glass” process only where legally required, with explicit reason, time limit and immediate audit/alert.

4. Functional Requirements

ID	Module	Requirement
FR-AUTH-01	Registration	Allow registration by email and/or mobile number with verification.
FR-AUTH-02	Authentication	Support sign-in, logout, password reset, session/device management and MFA for privileged roles.
FR-AUTH-03	Profile	Maintain role-specific user profiles and account status.
FR-PAT-01	Patient	Create/edit patient demographics, emergency contact and communication preferences.
FR-PAT-02	Family	Create dependent profiles and controlled delegate access.
FR-PAT-03	Consent	Grant/revoke consent by person, scope and date range.
FR-PROV-01	Doctor	Doctor profile: qualifications, specialty, license, languages, clinic affiliations, fees, biography, services and photos.
FR-PROV-02	Clinic	Clinic profile: branches, address/map, services, doctors, hours, contacts, images and verification status.
FR-PROV-03	Verification	Admin workflow to review licenses/credentials and publish verification badges.
FR-MATCH-01	Search	Search by condition, specialty, provider name, clinic, location and service.
FR-MATCH-02	Matching	Map a condition/care need to specialty then rank eligible verified providers.
FR-MATCH-03	Filters	Filter by location, availability, language, visit type, rating, fee/payment method and clinic.
FR-MATCH-04	Safety	Apply urgent/emergency safety rules before normal matching.
FR-BOOK-01	Availability	Doctors/clinics publish slots and schedule templates.
FR-BOOK-02	Booking	Book a slot atomically and prevent double booking.
FR-BOOK-03	Changes	Reschedule/cancel using configurable rules.

FR-BOOK-04	Reminders	Send confirmation and reminder notifications.
FR-MED-01	Encounter	Authorized doctor records consultation summary, findings, treatment plan and follow-up.
FR-MED-02	Prescription	Store prescription header and one or more drug items with dose/frequency/duration.
FR-MED-03	Lab	Create/record laboratory orders and results; attach result documents.
FR-MED-04	Imaging	Create/record diagnostic imaging orders and report summaries; attach images/reports.
FR-MED-05	Documents	Upload medical reports and files to encrypted object storage with metadata and malware scan status.
FR-MED-06	Timeline	Present patient history as chronological events across visits, drugs, tests, imaging and reports.
FR-MED-07	Amendments	Do not silently overwrite signed clinical notes; create version/amendment history.
FR-MED-08	Export	Allow patient-controlled export of permitted medical record data/documents.
FR-PAY-01	Payments	Initiate card/mobile-wallet payment through external gateway and store token/reference only.
FR-PAY-02	Webhooks	Verify payment gateway webhook signatures and update transaction state idempotently.
FR-PAY-03	Refunds	Support approved refund/cancellation workflow where applicable.
FR-REV-01	Review	Allow one review per completed appointment, 1–5 stars plus comment.
FR-REV-02	Moderation	Flag, hide, approve or reject abusive/spam content; retain moderation history.
FR-REV-03	Rating	Compute doctor/clinic rating using verified reviews and minimum-sample protection.
FR-ADS-01	Advertising	Manage advertisers, campaigns, placements, start/end dates, budgets and creative assets.
FR-ADS-02	Sponsored	Sponsored provider placement must be labeled and cannot modify the clinical match score.
FR-ADS-03	Privacy	Do not expose private medical-record fields to advertising systems.
FR-ADM-01	Admin	Dashboard for user/provider status, bookings, reviews, campaigns, payments, support and security.
FR-ADM-02	Audit	Search/export audit events for sensitive data access and privileged changes.
FR-ADM-03	Configuration	Manage specialties, condition-to-specialty mappings, matching weights, cancellation policies and content.
FR-ADM-04	Reporting	Operational reports for bookings, provider utilization, ratings, transactions, campaigns and system health.
FR-NOT-01	Notifications	Email/SMS/in-app notifications for booking, payment, results, consent and security events.
FR-NOT-02	Preferences	Allow user notification preferences except mandatory security/transactional notices.

5. Non-Functional Requirements

ID	Category	Requirement
NFR-SEC-01	Security	Use OWASP ASVS 5.0.0 as application-security verification baseline and address OWASP Top 10:2025 risks.
NFR-SEC-02	Encryption	TLS for data in transit; encryption at rest for database backups and object storage; managed key rotation.
NFR-SEC-03	Privacy	Data minimization, consent, purpose limitation, access logging and jurisdiction-specific retention/deletion policies.
NFR-SEC-04	Payments	Keep cardholder data out of the application using hosted/tokenized payment methods; align applicable payment scope with PCI DSS v4.0.1.
NFR-PERF-01	Latency	Target p95 API latency < 500 ms for normal CRUD/search APIs excluding third-party dependencies; p95 page interaction target < 2.5 s on typical broadband/mobile.
NFR-PERF-02	Capacity	Horizontally scale stateless API and realtime containers; use cache, queue and direct object-storage uploads.
NFR-AVL-01	Availability	MVP target 99.9%; growth target 99.95% with multi-AZ database and redundant application containers.
NFR-DR-01	Recovery	Define RPO ≤ 15 min and RTO ≤ 2 h for production target, subject to cloud/service budget.
NFR-A11Y-01	Accessibility	Design against WCAG 2.2 AA principles including keyboard operation, contrast, labels and error messaging.
NFR-UX-01	Responsive	Support desktop, tablet and modern mobile browsers; Bootstrap responsive grid and tested breakpoints.
NFR-I18N-01	Localization	Architecture should support multiple languages and RTL if future Arabic UI is required.
NFR-MNT-01	Maintainability	Modular domain services, documented APIs, automated tests, versioned database migrations and structured logging.
NFR-OBS-01	Observability	Central logs, metrics, traces, security alerts, uptime monitoring and synthetic booking checks.
NFR-DATA-01	Integrity	Foreign keys, constraints, transactions, idempotency keys and immutable audit/event history for critical actions.
NFR-SCL-01	Scalability	Separate large medical files from PostgreSQL; use object storage and CDN/presigned transfer where appropriate.

6. Matching, Rating and Business Rules

6.1 Safe Provider Matching

Matching should be explainable and deterministic enough to audit. The condition entered by the patient is first mapped to one or more specialties using an administrator-maintained clinical taxonomy. A safety rule evaluates whether the entered need is appropriate for ordinary outpatient matching; emergency patterns should show an emergency instruction rather than simply returning a ranked list.

Component	Weight	Rule
Clinical relevance / condition-specialty fit	35%	Hard gate plus score from condition-to-specialty mapping.
Subspecialty / services fit	15%	Relevant services, age group and procedure capability.
Availability	15%	Nearest acceptable appointment window.
Location / visit accessibility	15%	Distance/area, telehealth option if enabled, branch suitability.
Verified rating quality	10%	Only verified completed-visit reviews; stabilized for low sample sizes.
User preferences	10%	Language, visit type, gender preference where lawful, accessibility needs, payment method.

Example formula: Match Score = 0.35 Clinical Fit + 0.15 Subspecialty Fit + 0.15 Availability + 0.15 Location + 0.10 Rating Quality + 0.10 User Preference. Each component is normalized to 0–100. Advertising is excluded from this calculation.

6.2 Review and Rating Rule

Only a patient associated with a completed appointment may submit a review, normally one review per appointment. To prevent a doctor with one 5-star review from outranking a doctor with hundreds of stable reviews, use a Bayesian/weighted display rating: Displayed Rating = $(v/(v+m))\times R + (m/(v+m))\times C$, where R is the provider mean, v is verified review count, C is the platform mean, and m is a minimum confidence threshold such as 10 verified reviews.

6.3 Patient Count Rule

A public “patients served” figure should count verified completed appointments or unique patients, never expose identities, and should use clear wording such as “684 completed patient cases on this platform.” The doctor dashboard may show more detailed trends, subject to privacy and clinic relationships.

6.4 Advertising Rule

- Ads and sponsored cards are visibly labeled.
- Sponsored status does not increase the clinical match score.
- Private diagnoses, prescriptions, tests or record events are not passed to advertisers.
- Campaign analytics use aggregated/non-sensitive statistics where possible.
- Healthcare advertising categories, claims and targeting must be configurable by jurisdiction and platform policy.

7. Use Cases and User Journeys

Use Case	Primary Actor	Goal	Precondition	Success	Important Alternatives
UC-01 Register patient	Visitor	Create patient account	Valid email/mobile	Verified patient account	Duplicate contact; failed OTP; weak password
UC-02 Add family/dependent	Patient	Create dependent and consent relationship	Authenticated patient	Dependent profile with relationship	Minor/adult consent rules; duplicate dependent
UC-03 Find doctor by illness	Patient/Visitor	Map care need to specialty and rank providers	Condition/specialty taxonomy available	Relevant provider list	Urgent rule triggers emergency notice; no eligible provider
UC-04 Book appointment	Patient	Reserve doctor/clinic slot	Signed in; slot available	Confirmed appointment	Concurrent booking; payment failure; provider cancels
UC-05 Pay provider	Patient	Complete gateway payment	Appointment/payment request	Paid/failed/pending transaction	Wallet redirect; webhook delay; refund
UC-06 Record encounter	Doctor	Document visit and treatment	Authorized appointment relationship	Signed/versioned encounter	Access denied; amendment after sign-off
UC-07 Add prescription	Doctor	Add one or more drugs	Active encounter	Prescription visible in timeline	Incomplete dose/frequency; later amendment
UC-08 Add lab result	Doctor/Authorized provider	Attach test result	Patient relationship/consent	Result event + document	Pending result; corrected result; infected file rejected
UC-09 Add imaging result	Doctor/Authorized provider	Attach diagnostic imaging report	Patient relationship/consent	Imaging event + document	Large file redirected to object storage; PACS link later
UC-10 Review doctor	Patient	Submit stars and comment	Completed appointment	Review pending/approved	Duplicate review; abusive text; conflict of interest
UC-11 Manage provider verification	Admin verifier	Approve/suspend provider	Credentials submitted	Verification status updated	Expired/revoked credentials; insufficient evidence
UC-12 Grant family access	Patient	Delegate selected record access	Patient owns record	Scoped consent grant	Revoke; expired consent; legal guardian rule
UC-13 Run ad campaign	Advertiser/Admin	Publish compliant ad placement	Approved advertiser/creative	Campaign active	Policy rejection; budget/date exhausted
UC-14 Audit record access	Security/Compliance	Trace sensitive access	Privileged role	Audit report	Break-glass event; unusual access alert



Figure 2 — End-to-end patient journey and record lifecycle.

8. System Architecture and Technology Stack

8.1 Recommended Architecture

Use a modular web architecture with a React single-page application, Laravel as the authoritative business/clinical REST API, Node.js as a focused realtime/integration service, PostgreSQL as the transactional database, and encrypted object storage for reports/images. This avoids two competing “main backends”: Laravel owns domain transactions and Node.js owns WebSocket/event delivery and selected integration adapters.

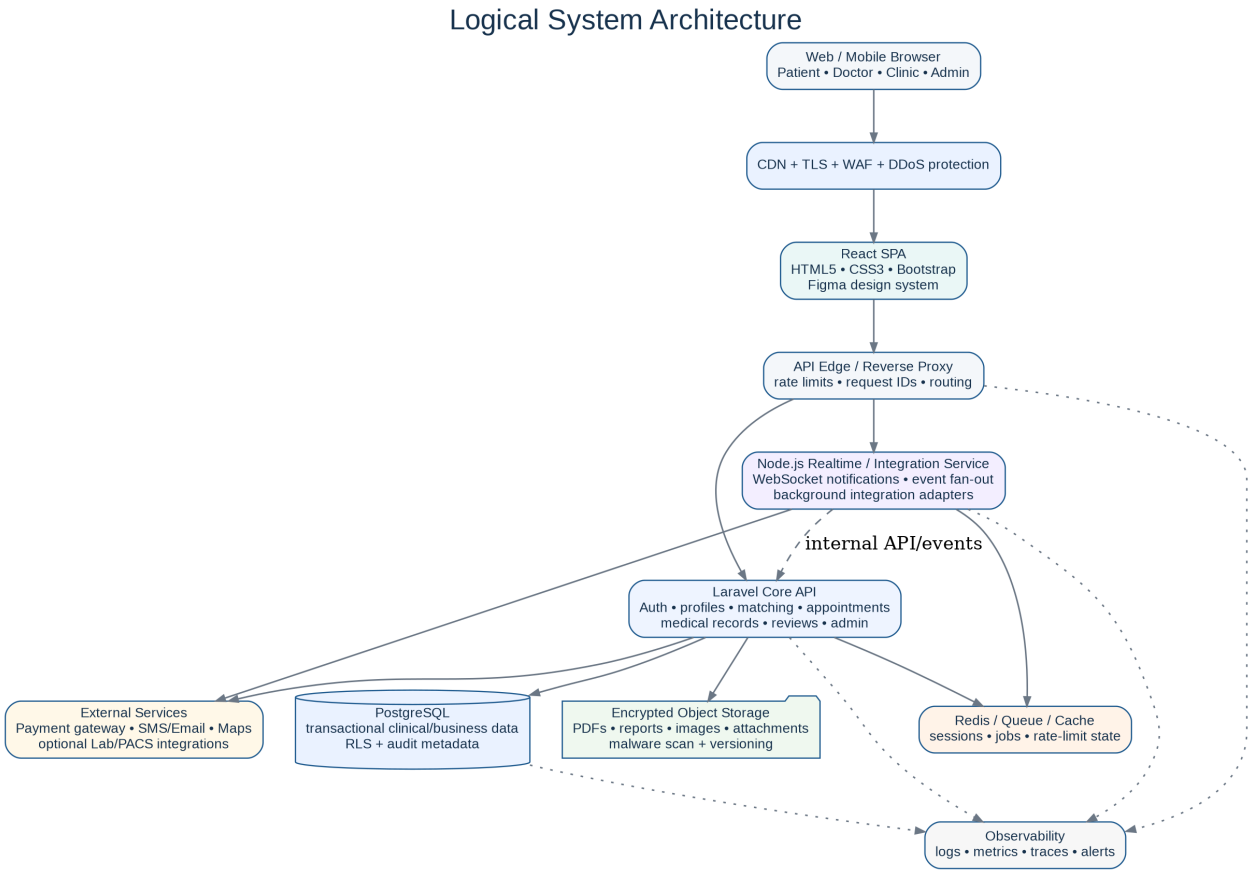


Figure 3 — Logical architecture and technology responsibilities.

Layer	Technology	Responsibilities
UI/UX design	Figma	User flows, wireframes, responsive components, design tokens, prototypes and handoff.
Frontend	React + HTML5 + CSS3 + Bootstrap	Public website, portals, forms, search, dashboards, accessibility and responsive behavior.
Core backend	PHP Laravel	Authentication integration, authorization, provider directory, matching, booking, clinical records, payments, reviews, ads/admin APIs.
Realtime / integration	Node.js	WebSocket notifications, event fan-out, optional integration adapters and realtime presence/status.
Database	PostgreSQL	Normalized transactional data, constraints, indexes, RLS, audit metadata and reporting views.
Cache / queue	Redis (recommended)	Rate limit state, cache, queues, job coordination and transient realtime state.
File storage	Cloud object storage	Medical reports, documents and images; encrypted, versioned and scanned.
Containerization	Docker	Repeatable build/runtime packaging for frontend origin, Laravel API, Node service and workers.
Cloud	Provider-neutral managed services	Load balancer, WAF/CDN, container platform, managed PostgreSQL/Redis, object storage, KMS/secrets and monitoring.

9. Database and Domain Design

PostgreSQL is the system of record for users, provider profiles, appointments, medical metadata, prescriptions, reviews, payment references, consent and audit data. Large binary files should not be stored as database BLOBs; store them in encrypted object storage and keep the object key, checksum, metadata, ownership and scan status in PostgreSQL.

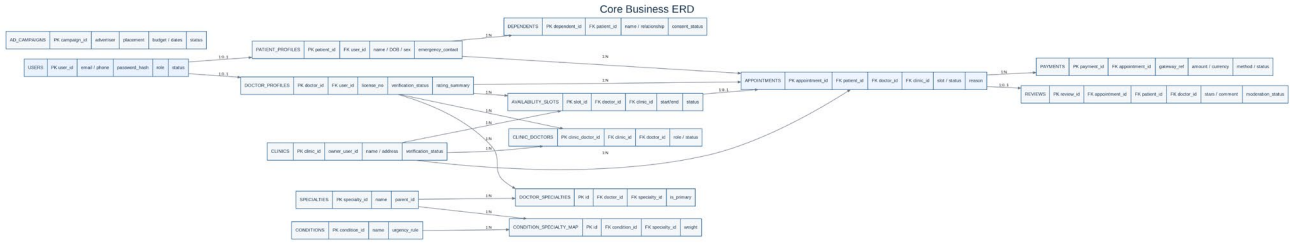


Figure 4 — Core business entities and cardinalities.

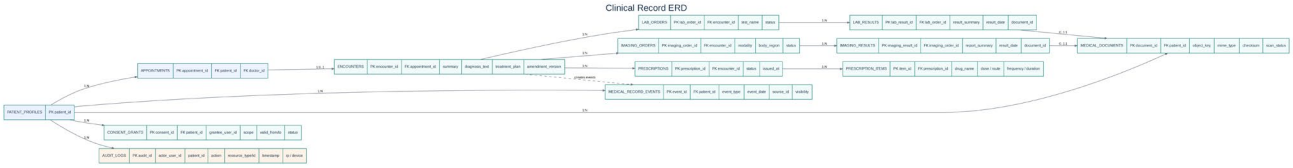


Figure 5 — Clinical record entities and audit/consent relationships.

9.1 Key Data-Model Rules

- Use UUIDs or other non-sequential public identifiers for external APIs; internal indexes remain optimized.
- Patient, doctor and clinic profiles reference a single users/identity table rather than duplicate login credentials.
- Many-to-many doctor/clinic and doctor/specialty relationships use join tables.
- Appointment booking is transactional; a slot may be linked to at most one active confirmed appointment.
- Encounter records are append/version oriented; signed records are amended with history rather than replaced invisibly.
- Medical timeline is a derived view/event stream over encounters, prescriptions, lab, imaging and documents.
- Consent grants have explicit grantee, scope, validity period and revoke state.
- Audit logs record actor, patient context, action, resource, time, device/IP context and outcome; logs should be protected from ordinary modification.
- Payment records contain gateway token/reference, amount, currency, method category and state; never persist CVV.

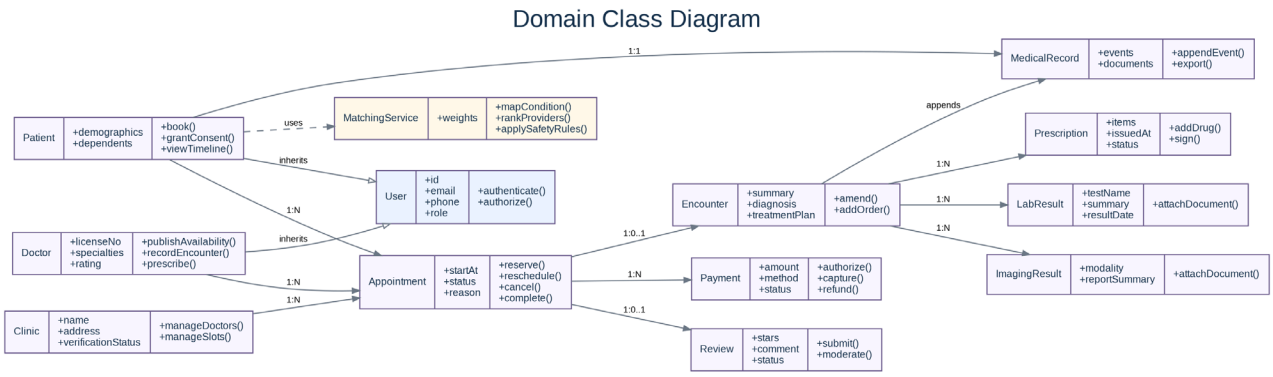


Figure 6 — Domain class model for application design.

10. Backend Development Responsibilities

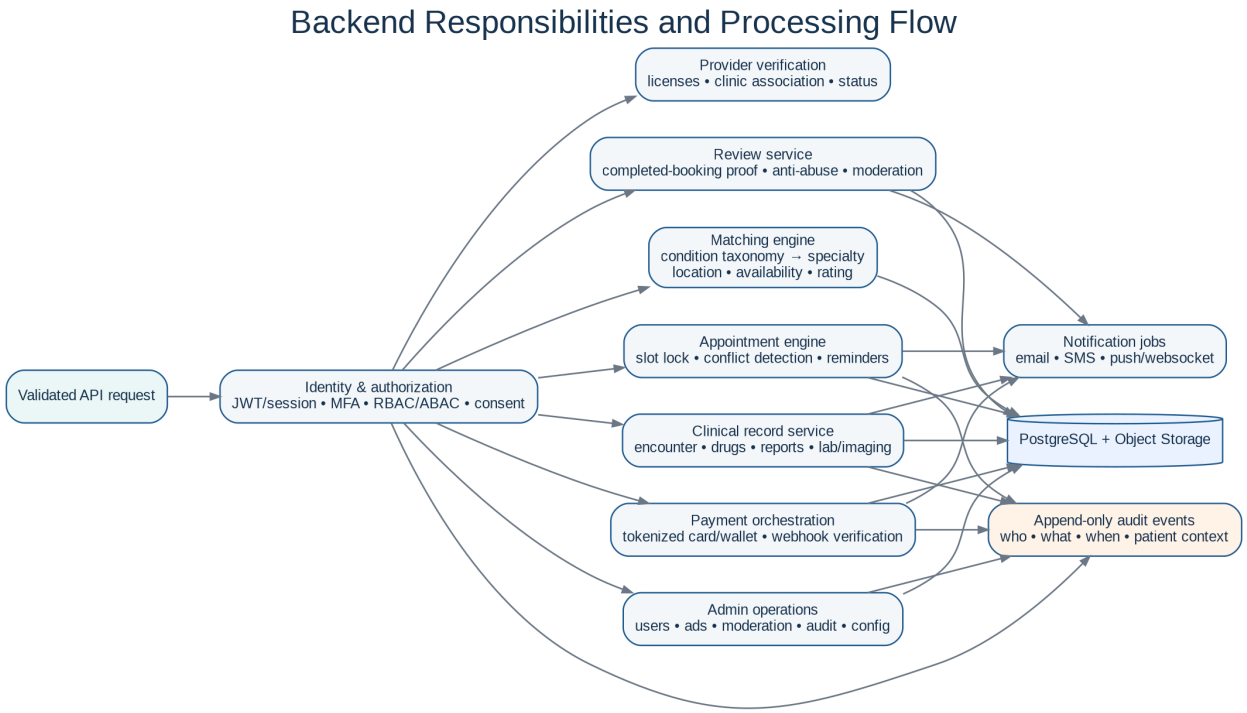


Figure 7 — Backend service responsibilities and cross-cutting audit flow.

Backend Area	Tasks / Deliverables
Identity & authorization	Registration, verification, MFA hooks, sessions/tokens, RBAC/ABAC, consent evaluation, device/session revocation.
Provider directory	Doctor/clinic CRUD, credentials, affiliations, specialties, services, verification lifecycle, public search indexes.
Matching	Condition taxonomy, specialty mappings, eligibility gates, ranking score, explanation fields and emergency safety override.
Scheduling	Availability templates, slot generation, time zones, conflict rules, appointment state machine, reschedule/cancel policies.
Clinical records	Encounters, note sign-off/amendments, prescriptions, test/imaging orders/results, timeline and document metadata.
Payments	Payment intents, gateway redirects/SDK tokens, signed webhook processing, idempotency, refunds and reconciliation export.
Reviews	Completed-visit eligibility, rating calculation, moderation queue, abuse flags, provider response rules if enabled.
Advertising	Campaign configuration, placement selection, creative approval, aggregate analytics, strict separation from medical matching.
Notifications	Queued email/SMS/in-app/WebSocket events; retries and dead-letter handling.
Admin & reporting	User/provider status, support, content, transactions, audit, configuration, export and operational dashboards.
Security & operations	Rate limits, validation, anti-automation, structured logs, metrics, audit events, backups and security alerts.

11. Frontend and UI/UX Design

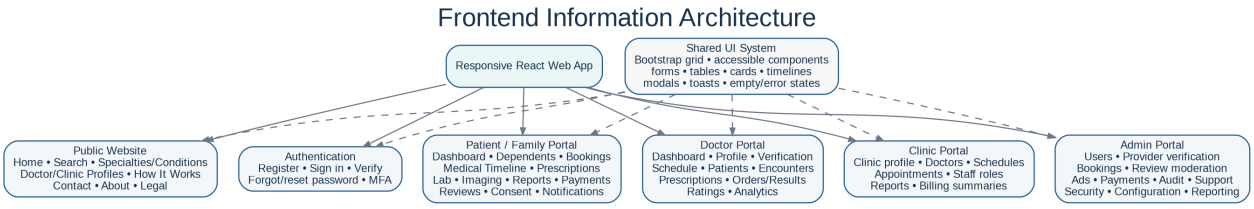


Figure 8 — React frontend information architecture and shared component system.

11.1 Figma Design System

- Create desktop, tablet and mobile frames for every primary flow.
- Use a calm healthcare palette: deep blue for trust/navigation, teal for clinical actions/status, neutral gray backgrounds, and restrained red only for danger/urgent states.
- Define tokens for typography, spacing, radius, elevation, input states, badges and semantic status colors.
- Bootstrap provides layout/grid utilities; custom CSS variables should map Figma tokens to implementation.
- All forms need visible labels, help text, validation summary, inline errors and loading/success/error states.
- Clinical history uses a timeline pattern; reports use cards/tables with filters rather than dense free text.
- Privileged clinical actions require confirmation and clear patient context to reduce wrong-patient errors.

11.2 Proposed UI Concepts

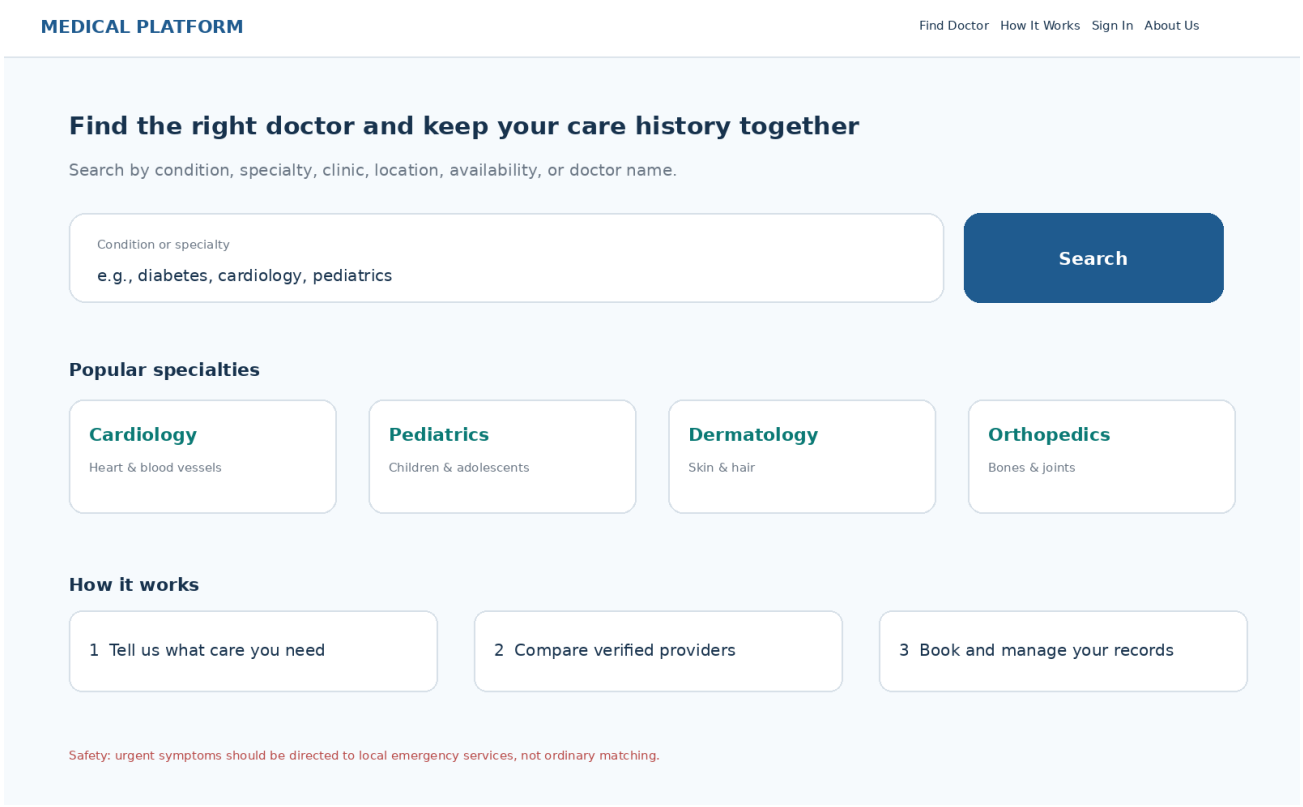


Figure 9 — Proposed Home / provider discovery landing page.

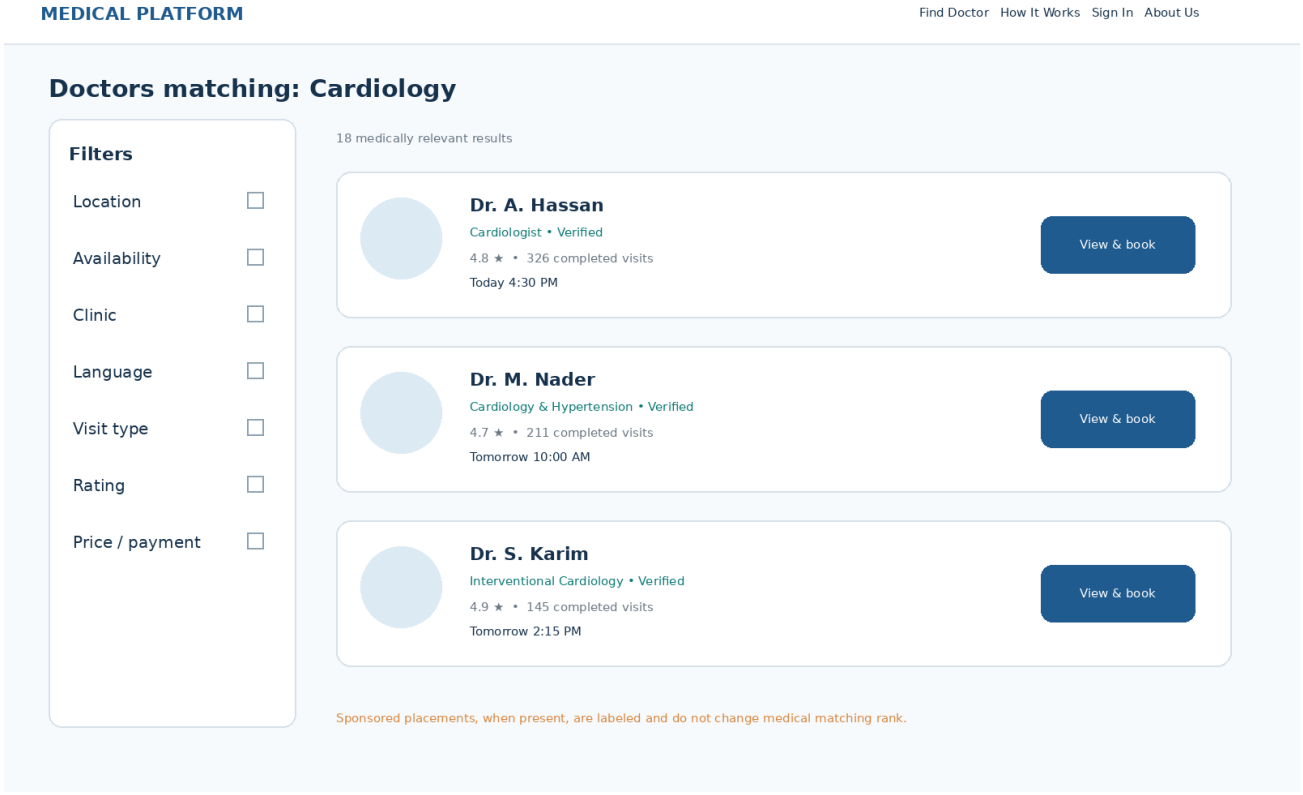


Figure 10 — Proposed provider search and matching results page.

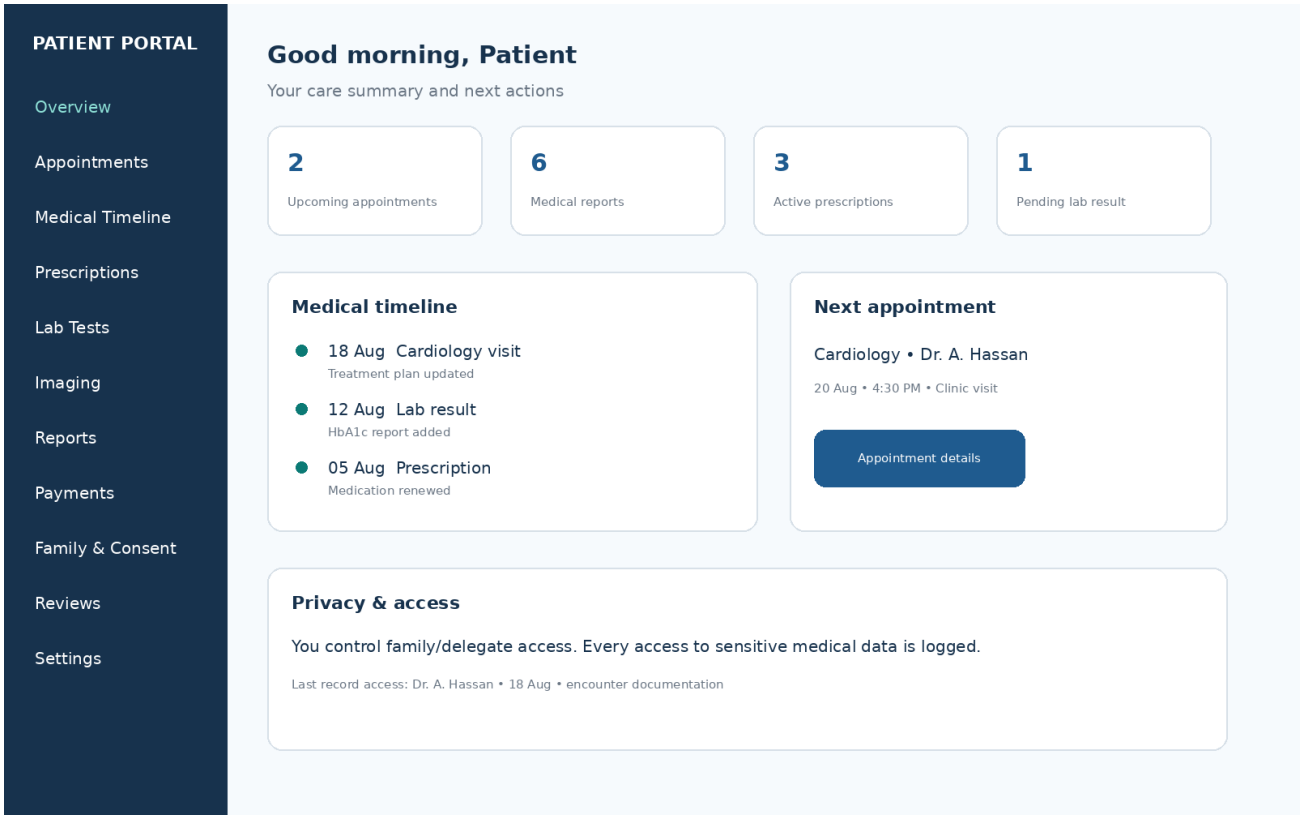


Figure 11 — Proposed patient/family dashboard with medical timeline.

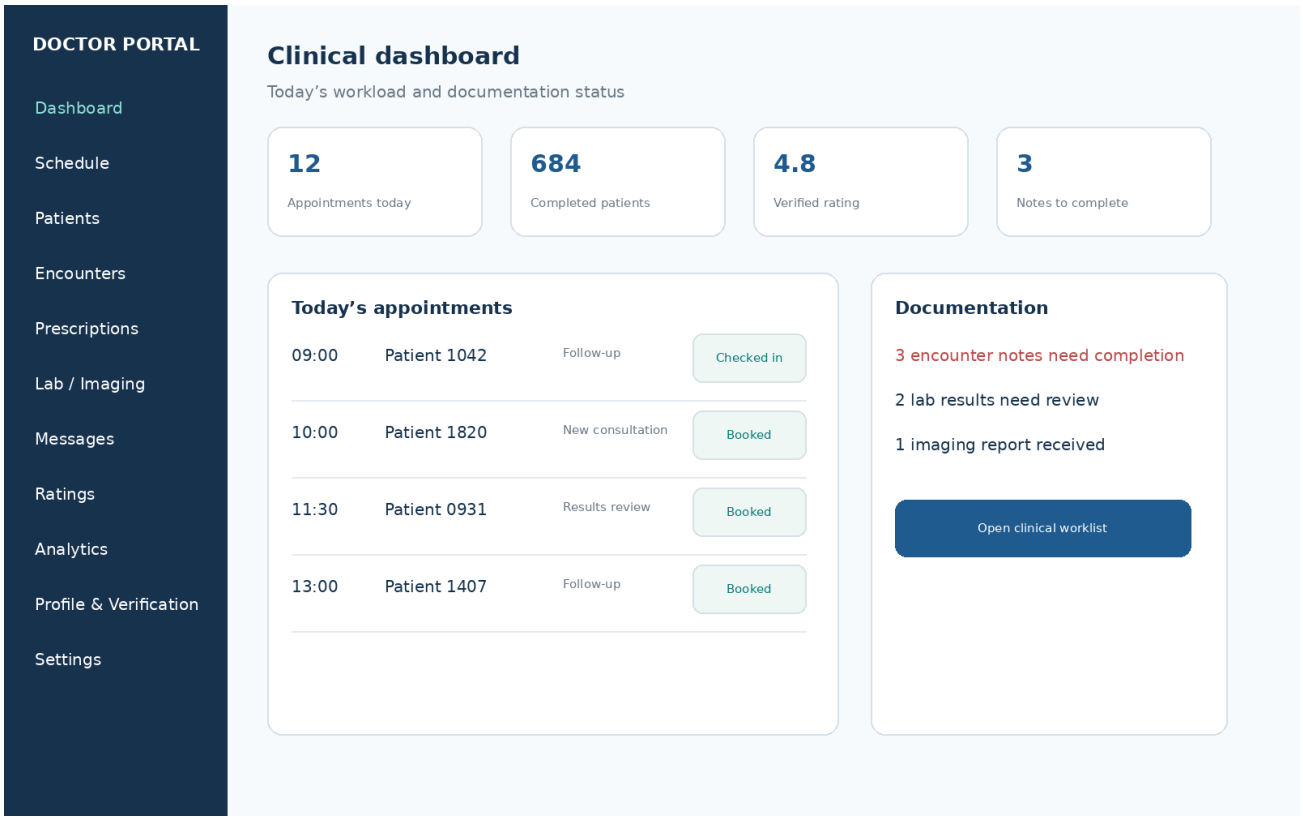


Figure 12 — Proposed doctor dashboard and clinical worklist.

12. Web Page Inventory and Navigation

Area	Page	Purpose / Main UI
Public	Home	Value proposition, main search, specialties, trust/verification, how it works, CTA, safety notice.
Public	Find a Doctor	Condition/specialty search, filters, medical-relevance results, labeled sponsored placements.
Public	Find a Clinic	Clinic search, location, services, doctors, hours and ratings.
Public	Doctor Profile	Verified status, specialties, credentials, clinics, availability, fees/payment options, reviews, completed patient count.
Public	Clinic Profile	Branches, services, verified doctors, opening hours, map, booking options and reviews.
Public	Specialties & Conditions	Browsable taxonomy and educational routing to the correct specialty; no autonomous diagnosis.
Public	How It Works	Patient flow, provider verification, records, payments and review policy.
Public	For Doctors	Benefits, onboarding, verification requirements and portal overview.
Public	For Clinics	Clinic onboarding, multi-doctor scheduling and portal overview.
Public	Advertising / Partners	Campaign options, content policy, privacy boundary, contact/lead form.
Public	Contact Us	Support categories, contact form, emergency disclaimer and operating contact information.
Public	About Us	Mission, trust model, leadership/company content, medical safety boundary and privacy principles.
Public	Privacy Notice	Data categories, purposes, sharing, retention, rights, cookies and contact.
Public	Terms of Use	Platform terms, provider responsibility, reviews, bookings, payment and acceptable use.
Public	Cookie Preferences	Consent choices for necessary, analytics and advertising cookies as required.
Auth	Register / Sign In	Role choice, email/mobile verification, password, MFA/verification steps.
Patient	Patient Dashboard	Upcoming appointments, alerts, recent results, medical timeline summary, quick actions.
Patient	My Profile & Dependents	Demographics, emergency contact, family/dependent relationships.
Patient	Bookings	Upcoming/past appointments, reschedule/cancel, booking detail and reminders.
Patient	Medical Timeline	All visits, diagnoses/summary, treatments, prescriptions, tests, imaging and reports.
Patient	Prescriptions	Current/historical prescriptions and item details.
Patient	Laboratory Tests	Orders, statuses, result summaries, downloadable documents.
Patient	Diagnostic Imaging	Orders, modality, report summary, attachments/PACS link if integrated.
Patient	Medical Reports	Uploaded/received documents with date, source, type, preview/download rights.
Patient	Payments	Payment requests, status, receipt, refund history; no raw card data display.
Patient	Reviews	Eligible appointments, submitted reviews and moderation status.
Patient	Family & Consent	Grant/revoke access and view access history.
Patient	Notifications & Settings	Preferences, sessions/devices, password/MFA, privacy/export requests.
Doctor	Doctor Dashboard	Today schedule, patient counts, pending documentation/results, rating and alerts.
Doctor	Schedule & Availability	Weekly templates, exceptions, slots, leave and clinic locations.
Doctor	Patients / Appointments	Authorized appointment-linked patient list and visit context.
Doctor	Encounter Workspace	Structured consultation note, treatment plan, prescription, orders, attachments and sign-off.
Doctor	Clinical Results	Lab/imaging worklist, result review and follow-up status.
Doctor	Analytics	Completed visits, no-shows, rating trends, availability utilization.
Doctor	Profile & Verification	Credentials, specialties, clinic affiliations, public profile preview and verification state.
Clinic	Clinic Dashboard	Branch activity, doctors, appointments, utilization and operational metrics.
Clinic	Doctors & Staff	Affiliations, staff roles and permission assignments.
Clinic	Schedules	Branch/doctor availability and appointment operations.
Admin	Admin Dashboard	System health, registrations, provider verification, bookings, reviews, payments, ads and security alerts.
Admin	Users & Roles	Account search, status, role assignment, support action with audit.
Admin	Provider Verification	Credential queue, evidence, expiry, approval/suspension.
Admin	Bookings	Appointment search, exceptions, disputes and support tools.
Admin	Reviews & Moderation	Flags, moderation decisions, appeals/history.
Admin	Ads & Campaigns	Advertiser, creative, placement, schedule, budget and performance.
Admin	Payments & Reconciliation	Transactions, webhook state, refunds and finance export.
Admin	Medical Access Audit	Who accessed which patient resource and why; anomaly investigation.
Admin	System Configuration	Taxonomies, mapping weights, policies, notifications, feature flags and integrations.
Admin	Monitoring & Support	Health checks, background jobs, errors, tickets, system notices and maintenance mode.

13. Security, Privacy and Payment Design

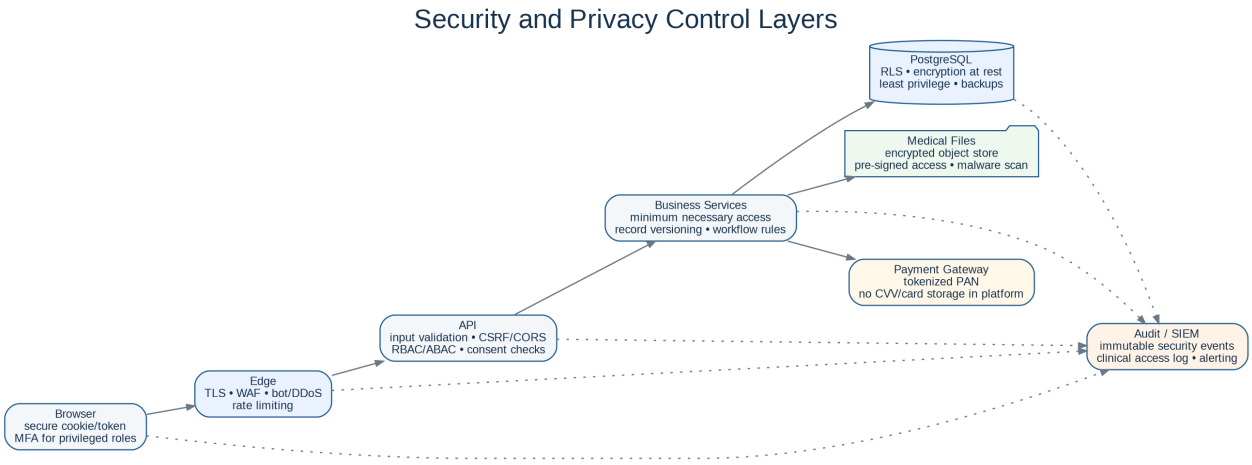


Figure 13 — Security and privacy controls from browser to data stores.

13.1 Security Controls

Domain	Required Design
Identity	Strong password policy, verified email/mobile, MFA for doctor/clinic-admin/platform-admin, session revocation, suspicious-login alerts.
Authorization	RBAC + ownership/relationship checks + consent; database RLS on patient-scoped tables; deny-by-default policies.
API security	Schema validation, rate limiting, CSRF protection where relevant, strict CORS, anti-enumeration, idempotency keys, no verbose production errors.
Encryption	TLS 1.2+ or modern cloud baseline in transit; encryption at rest; KMS-managed keys; encrypted backups.
Medical files	Pre-signed time-limited URLs, object-level authorization, malware scanning, MIME validation, checksums, versioning and no public buckets.
Audit	Immutable/append-oriented clinical-access and privileged-change events; alert on unusual or break-glass access.
Secure SDLC	SAST, dependency/SBOM scanning, secrets scanning, DAST/API tests, image scanning and peer review before deployment.
Infrastructure	WAF, DDoS protection, private database network, least-privilege service identities, secrets manager, patching and hardened containers.
Backups/DR	Point-in-time database recovery, object versioning, offsite/region strategy as required, scheduled restore tests.
Incident response	Severity matrix, owner/on-call, evidence preservation, token/key revocation, user notification workflow as legally required.

13.2 Payment Security

- Use hosted payment pages or gateway tokenization for bank cards and mobile wallets.
- Never store CVV; avoid storing PAN entirely. Store only gateway customer/payment tokens, transaction reference, last-4/brand if returned and legally/contractually permitted.
- Validate gateway webhook signatures, timestamp/replay protections and idempotency.
- Separate finance permissions from clinical permissions.
- PCI DSS v4.0.1 is the current PCI SSC baseline referenced by this design; exact merchant/service-provider scope depends on the chosen gateway integration.

13.3 Privacy and Medical Data

- Classify medical history, diagnoses, drugs, laboratory/imaging results and reports as highly sensitive data.
- Collect only what is necessary for care coordination and platform operations.
- Define retention, deletion, correction and patient-access/export rules based on the deployment jurisdiction before production.

- Family access is explicit, scoped and revocable; adult family members do not automatically see another adult's records.
- Provider access is relationship-based (appointment/encounter/authorized care relationship) and audited.
- Ads/analytics should not receive raw private medical data. Prefer first-party aggregation and privacy-preserving metrics.

13.4 Security Coverage Calculation

Use a weighted release-readiness score rather than claiming that a design diagram is "secure." Each domain is scored 0 = absent, 0.5 = designed/planned, 0.8 = implemented, 1.0 = implemented and independently verified. Security Coverage % = Σ(weight × score). Production release target: ≥ 90%, with no critical domain below 0.8 and all payment/authentication/access-control controls required for the release implemented.

Security Domain	Weight
Identity & authentication	15%
Authorization/RLS/consent	15%
Encryption & key management	12%
Audit & logging	10%
Application/API security	12%
Infrastructure/network security	10%
Payment security	8%
Privacy/data governance	10%
Backup/DR	5%
Monitoring/incident response	3%

14. Performance, Bandwidth, Availability and Capacity Calculations

Sizing assumptions
The following figures are engineering planning examples, not measured production results. They provide a reproducible baseline for cloud sizing and must be recalculated after load testing and real traffic data become available.

14.1 API Load and Dynamic Bandwidth

Nominal API requests/second (RPS) = Peak Concurrent Users × Active Requests per User per Minute ÷ 60. Dynamic bandwidth ≈ RPS × Average API Payload KB × 8 ÷ 1000. Design capacity below applies 2.5× headroom for spikes, retries and uneven traffic. Static React/marketing assets should be served by CDN and are not included in the API number.

Stage	Registered	DAU	Peak concurrent	Req/user/min	Nominal RPS	Design RPS	Nominal API BW	Design API BW
MVP	25,000	3,000	300	8	40	100	17.6 Mbps	44 Mbps
Growth	150,000	20,000	1,200	10	200	500	104.0 Mbps	260 Mbps
Scale	1,000,000	100,000	5,000	12	1000	2500	600.0 Mbps	1500 Mbps

14.2 Medical File Storage

Medical uploads should go directly from browser to encrypted object storage using a short-lived pre-signed upload request after the API authorizes the action. This keeps large file traffic away from Laravel/Node containers. Illustrative annual storage below assumes average report/attachment sizes and a 2× planning reserve for versions, backups and growth.

Stage	Medical files/day	Avg file	Raw annual growth	Planned storage reserve
MVP	500	5 MB	0.91 TB/year	1.82 TB/year
Growth	5,000	8 MB	14.60 TB/year	29.20 TB/year
Scale	25,000	10 MB	91.25 TB/year	182.50 TB/year

If the platform stores full diagnostic-imaging DICOM studies rather than reports/selected images, storage and network requirements can increase by an order of magnitude or more. A dedicated PACS/DICOM strategy should therefore be treated as a separate integration phase.

14.3 Database / Search Performance Targets

- Use composite indexes for active appointment queries (doctor_id + start_at + status), patient timeline (patient_id + event_date), provider search filters, verification status, and review aggregates.
- Use PostgreSQL full-text/trigram search or a dedicated search service later if provider/condition search outgrows database search.
- Cache mostly-public provider profile/search metadata briefly; never cache private patient records in shared public caches.
- Use connection pooling and read replicas only when workload measurements justify them.
- Run load tests for search, booking race conditions, patient timeline and gateway webhook spikes before launch.

14.4 Availability Coverage

Availability SLO	Approx. downtime/month	Recommended use
99.90%	43.83 minutes/month	MVP
99.95%	21.92 minutes/month	Growth target
99.99%	4.38 minutes/month	High-cost/advanced target

A multi-AZ managed PostgreSQL service, at least two API replicas, redundant load balancer, object storage, health checks and automated restart/deploy rollback are the minimum architecture for a credible 99.9–99.95% service target. Actual SLA depends on cloud product SLAs and operational maturity.

15. Docker, Cloud Deployment and DevOps

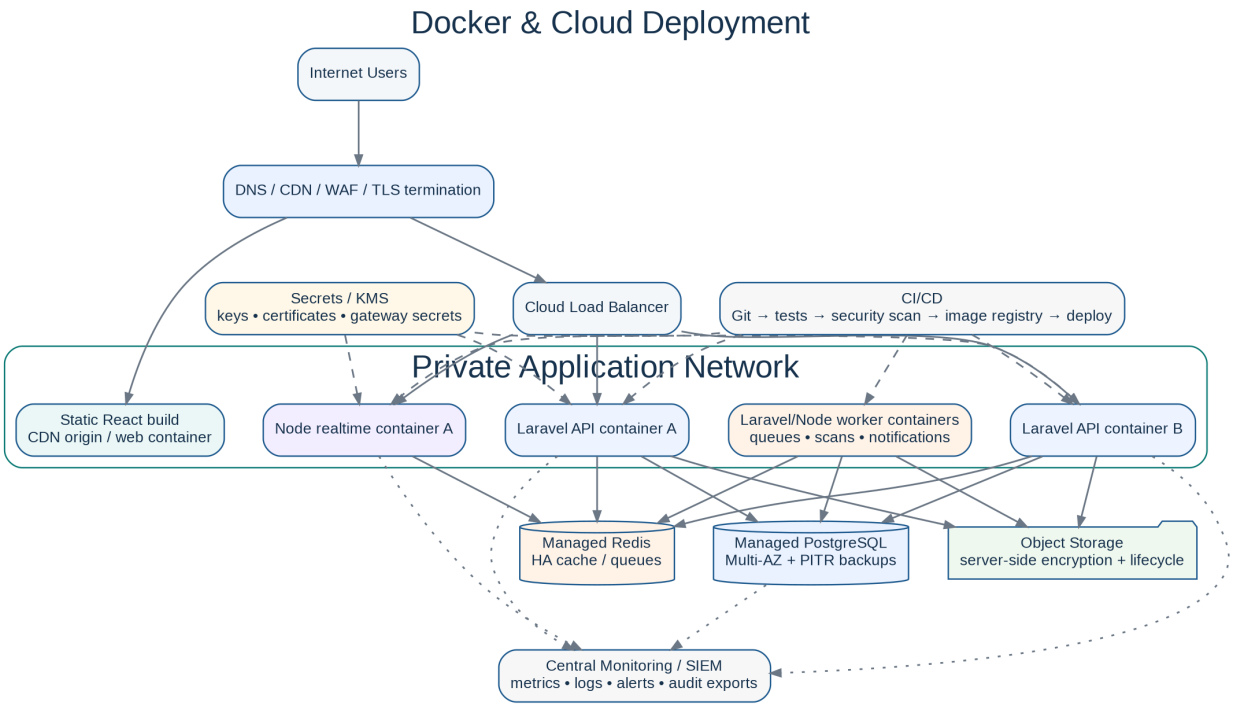


Figure 14 — Containerized cloud deployment and managed data services.

15.1 Docker Services

Container / Service	Purpose
frontend	React production build or origin service; static assets primarily cached through CDN.
laravel-api	Core REST API; stateless and horizontally scalable.
node-realtime	WebSocket/realtime event delivery and integration adapters.
worker	Queue processing: notifications, report scans, exports, webhook follow-up and asynchronous jobs.
scheduler	Scheduled tasks: reminders, expiry checks, campaign activation, cleanup and reports.
postgres / redis for local dev only	Local Docker Compose development; production should prefer managed HA database/cache services.

15.2 CI/CD Pipeline

1. Pull request with code review and automated unit/integration tests.
2. Run linting, SAST, dependency/SBOM scan, secrets scan and container image scan.
3. Build versioned Docker images and push to private registry.
4. Deploy to staging; run database migrations, API smoke tests, UI E2E tests and security checks.
5. Approval gate for production; rolling/blue-green deployment with health checks.
6. Post-deploy synthetic tests: sign-in, search, booking, payment callback test environment, record access and notification job.
7. Automatic rollback or operator rollback on failed health/SLO thresholds.

15.3 Environments

Environment	Data Rule	Purpose
Local	Synthetic only	Developer work and automated tests.
Development	Synthetic/anonymized only	Shared integration development.
Staging/UAT	Synthetic or formally de-identified	Release validation, performance and security testing.
Production	Real patient/provider data	Strict access, audit, backups, monitoring and incident response.

16. Testing and Quality Assurance

Test Area	Minimum Coverage
Unit tests	Matching components, rating formula, appointment state transitions, consent rules, payment webhook verification.
API integration	Authorization boundaries, CRUD constraints, file metadata, provider verification, booking/payment flows.
Concurrency	Two users attempt same slot; only one confirmed reservation.
Security	OWASP ASVS-based verification, auth/access-control tests, IDOR tests, rate-limit abuse, file upload attacks, injection, secrets and dependency checks.
Privacy	Patient A cannot access Patient B; family access follows consent; clinic/doctor relationship boundaries; admin least privilege.
Payment	Success/fail/pending/refund, duplicate webhook, replay/tampered signature, timeout and reconciliation.
UI/E2E	Registration, search, booking, medical timeline, doctor encounter, moderation and responsive/mobile accessibility.
Performance	Search and timeline p95, booking throughput, notification queue spike, large report upload and object-storage path.
Recovery	Database point-in-time restore, object version restore, secrets rotation and container redeploy.
UAT	Patient, doctor, clinic and admin role acceptance scenarios with representative users.

17. MVP Delivery Phases and Team Workstreams

Phase	Deliverables
Phase 0 — Product & compliance discovery	Confirm jurisdiction, provider verification rules, record retention, consent model, payment gateway, ad policy and clinical safety wording.
Phase 1 — UX foundation	Figma design system, sitemap, public pages, registration/login, role dashboards and responsive React shell.
Phase 2 — Directory & booking	Provider/clinic profiles, verification, specialties/conditions, matching, availability and appointment state machine.
Phase 3 — Medical record	Encounter workspace, prescription, laboratory/imaging results, documents, timeline, consent and audit.
Phase 4 — Payments, reviews & ads	Gateway integration, wallet/card flow, reconciliation, verified review moderation, advertising management.
Phase 5 — Hardening & launch	Security review, performance test, accessibility QA, backup/restore test, monitoring, incident runbooks and production deployment.

17.1 Frontend Workstream

- Figma-to-React component library
- Routing and role-aware navigation
- Forms and validation
- Search/filter/result components
- Booking calendar/slot UI
- Medical timeline and document viewers
- Dashboards/tables/charts
- Payment redirect/status UI
- Review/comment UI
- Accessibility/responsive/browser QA

17.2 Backend Workstream

- Database schema/migrations/seed taxonomies
- Laravel APIs and authorization policies
- Node realtime service
- Matching/rating algorithms
- Scheduling/booking transactions
- Clinical record domain and audit
- Object storage/file scanning
- Payment gateway/webhooks
- Review moderation and ad APIs
- Admin/reporting endpoints
- Observability/security/backup automation

18. Assumptions, Risks and Future Enhancements

Risk / Assumption	Why It Matters	Design Response
Jurisdiction not specified	Privacy, medical-record retention, telemedicine, advertising and provider verification obligations vary by country.	Resolve legal/regulatory requirements before production architecture is frozen.
Clinical matching ambiguity	Users may enter symptoms/diagnoses inconsistently.	Start with curated condition/specialty taxonomy, synonyms and explicit safety rules; avoid autonomous diagnosis.
Dual backend complexity	Laravel + Node can duplicate logic if boundaries are unclear.	Laravel owns authoritative business transactions; Node owns realtime/integration only.
Medical imaging size	Raw studies can be very large.	Store reports/selected attachments first; integrate PACS/DICOM in a dedicated phase.
Advertising trust	Sponsored providers may be perceived as clinically preferred.	Clear "Sponsored" label and strict separation from matching score.
Fake reviews	Open comments are easily manipulated.	Require completed appointment, fraud signals, moderation and stabilized rating formula.
Admin overreach	Central admins could become a privacy risk.	Least privilege, clinical-content separation, JIT elevation and audited break-glass.
Payment scope	Direct card handling increases compliance burden.	Hosted/tokenized gateway and no PAN/CVV storage.
Provider data accuracy	License/status can expire.	Credential expiry tracking and re-verification workflow.
Record integrity	Editing signed notes can create medico-legal disputes.	Versioned amendments with author/time/reason and audit trail.

18.1 Future Enhancements

- Telemedicine/video consultation with consent and session security.
- FHIR-based interoperability for external health systems where supported.
- PACS/DICOM integration for full diagnostic imaging workflows.
- Lab integrations for electronic orders/results.
- Insurance eligibility and claims integrations.
- Native iOS/Android applications sharing the same APIs.
- Privacy-preserving recommendation analytics and provider quality dashboards.
- Clinically governed symptom intake/triage module as a separately validated product, not a casual extension of search.

19. Acceptance Criteria

Area	Acceptance Criterion
Identity	A new patient, doctor and clinic user can register, verify contact, sign in/out and recover access; privileged roles support MFA.
Provider verification	Unverified providers cannot display a verified badge; admin action is audited.
Matching	Condition maps to appropriate specialty; ranking is explainable; sponsored status does not alter score; emergency rule can override normal search.
Booking	No double booking under concurrency; status transitions and notifications are consistent.
Records	Authorized clinician can create encounter/prescription/results; patient sees them in timeline; unauthorized users are denied and logged.
Family consent	Patient can grant and revoke scoped access; delegate access follows scope immediately.
Payments	Successful/failed/pending/refund states reconcile from signed gateway events without storing raw card/CVV data.
Reviews	Only completed appointments can create a review; one review per appointment; moderation history retained.
Admin	Role-separated admin functions work; clinical access is not granted merely by being a generic administrator.
Files	Medical files are private, encrypted, scanned, checksum tracked and delivered through authorized time-limited access.
Performance	Load test meets agreed stage RPS and p95 latency with stated headroom.
Recovery	Backup restore test meets agreed RPO/RTO target.
Accessibility	Critical user flows meet agreed WCAG 2.2 AA verification checklist.
Security	Security coverage release score ≥ 90%, no critical domain below 0.8, and no unresolved critical/high security findings accepted without documented risk approval.

20. Standards and Reference Baseline

The report uses the following current technical baselines as of August 2026. Exact legal compliance still depends on the country of operation and the final payment/cloud vendors.

Reference	How It Is Used
OWASP ASVS 5.0.0	Application-security verification requirements and release security checklist baseline.
OWASP Top 10:2025	Current web-application risk awareness categories used to guide threat coverage.
PCI DSS v4.0.1	Payment-card security baseline; design minimizes scope through external hosted/tokenized payment processing.
PostgreSQL 18 current documentation — Row Security Policies	Database-level patient/tenant row-access enforcement in addition to application authorization.
W3C WCAG 2.2	Accessibility baseline for patient/provider/admin web interfaces.

Final pre-production requirement
Before launch, add the specific healthcare, privacy, electronic-record, advertising, consumer-protection, tax/payment and provider-licensing rules for the deployment country. This report intentionally keeps legal requirements jurisdiction-neutral because no operating country was specified.

Conclusion

This design gives the project a scalable MVP path without turning the first release into a hospital information system. The core value remains provider discovery and booking, but the architecture is deliberately strong enough to preserve a patient-centered longitudinal history, support verified reviews and payments, and grow toward clinical integrations later. The most important implementation controls are strict separation of clinical matching from advertising, consent-based patient/family access, relationship-based clinician access, immutable audit history, externalized payment-card handling, and direct encrypted object-storage handling for medical files.

Acronym	Meaning
API	Application Programming Interface
UI	User Interface
UX	User Experience
SPA	Single-Page Application
PWA	Progressive Web Application
HTML	HyperText Markup Language
CSS	Cascading Style Sheets
JS	JavaScript
JSX	JavaScript XML
DOM	Document Object Model
REST	Representational State Transfer
REST API	Representational State Transfer Application Programming Interface
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
URL	Uniform Resource Locator
URI	Uniform Resource Identifier
JSON	JavaScript Object Notation
XML	Extensible Markup Language
SQL	Structured Query Language
DB	Database
DBMS	Database Management System
RDBMS	Relational Database Management System
ERD	Entity Relationship Diagram
PK	Primary Key
FK	Foreign Key
UUID	Universally Unique Identifier
CRUD	Create, Read, Update, Delete
ORM	Object-Relational Mapping
RBAC	Role-Based Access Control
ABAC	Attribute-Based Access Control
RLS	Row-Level Security
ACL	Access Control List
MFA	Multi-Factor Authentication
2FA	Two-Factor Authentication
SSO	Single Sign-On
OTP	One-Time Password
JWT	JSON Web Token

Acronym	Meaning
OAuth	Open Authorization
OIDC	OpenID Connect
TLS	Transport Layer Security
SSL	Secure Sockets Layer
AES	Advanced Encryption Standard
AES-256	Advanced Encryption Standard using a 256-bit key
RSA	Rivest-Shamir-Adleman Encryption Algorithm
SHA	Secure Hash Algorithm
SHA-256	Secure Hash Algorithm with a 256-bit digest
PII	Personally Identifiable Information
PHI	Protected Health Information
ePHI	Electronic Protected Health Information
EHR	Electronic Health Record
EMR	Electronic Medical Record
PHR	Personal Health Record
HIS	Hospital Information System
LIS	Laboratory Information System
RIS	Radiology Information System
PACS	Picture Archiving and Communication System
DICOM	Digital Imaging and Communications in Medicine
HL7	Health Level Seven
FHIR	Fast Healthcare Interoperability Resources
ICD	International Classification of Diseases
ICD-10	International Classification of Diseases, 10th Revision
SNOMED CT	Systematized Nomenclature of Medicine Clinical Terms
LOINC	Logical Observation Identifiers Names and Codes
CPT	Current Procedural Terminology
RxNorm	Standardized Nomenclature for Clinical Drugs
MRN	Medical Record Number
DOB	Date of Birth
BMI	Body Mass Index
BP	Blood Pressure
HR	Heart Rate
ECG	Electrocardiogram
EKG	Electrocardiogram
CT	Computed Tomography
MRI	Magnetic Resonance Imaging

Acronym	Meaning
PET	Positron Emission Tomography
US	Ultrasound
CBC	Complete Blood Count
HbA1c	Hemoglobin A1c
KPI	Key Performance Indicator
SLA	Service Level Agreement
SLO	Service Level Objective
RTO	Recovery Time Objective
RPO	Recovery Point Objective
HA	High Availability
DR	Disaster Recovery
CDN	Content Delivery Network
DNS	Domain Name System
WAF	Web Application Firewall
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
SIEM	Security Information and Event Management
DDoS	Distributed Denial of Service
XSS	Cross-Site Scripting
CSRF	Cross-Site Request Forgery
SQLi	SQL Injection
CSP	Content Security Policy
CORS	Cross-Origin Resource Sharing
OWASP	Open Worldwide Application Security Project
PCI DSS	Payment Card Industry Data Security Standard
CVV	Card Verification Value
PAN	Primary Account Number
PSP	Payment Service Provider
POS	Point of Sale
OTP	One-Time Password
KYC	Know Your Customer
AML	Anti-Money Laundering
QR	Quick Response
SMS	Short Message Service
SMTP	Simple Mail Transfer Protocol
WebSocket	Full-Duplex Communication Protocol over a Persistent Connection
SSE	Server-Sent Events

Acronym	Meaning
CDN	Content Delivery Network
TCP	Transmission Control Protocol
IP	Internet Protocol
TCP/IP	Transmission Control Protocol / Internet Protocol
VPN	Virtual Private Network
VPC	Virtual Private Cloud
VM	Virtual Machine
VPS	Virtual Private Server
CPU	Central Processing Unit
RAM	Random Access Memory
SSD	Solid-State Drive
IOPS	Input/Output Operations Per Second
RPS	Requests Per Second
TPS	Transactions Per Second
DAU	Daily Active Users
MAU	Monthly Active Users
CCU	Concurrent Users
TTFB	Time to First Byte
CDN	Content Delivery Network
CI	Continuous Integration
CD	Continuous Delivery / Continuous Deployment
CI/CD	Continuous Integration and Continuous Delivery/Deployment
IaC	Infrastructure as Code
DevOps	Development and Operations
DevSecOps	Development, Security and Operations
QA	Quality Assurance
UAT	User Acceptance Testing
SIT	System Integration Testing
E2E	End-to-End
MVP	Minimum Viable Product
PoC	Proof of Concept
MVP	Minimum Viable Product
CMS	Content Management System
CRM	Customer Relationship Management
ERP	Enterprise Resource Planning
SEO	Search Engine Optimization
SEM	Search Engine Marketing

Acronym	Meaning
CTA	Call to Action
FAQ	Frequently Asked Questions
TOS	Terms of Service
SLA	Service Level Agreement
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
PCI	Payment Card Industry
WCAG	Web Content Accessibility Guidelines
ADA	Americans with Disabilities Act
DPIA	Data Protection Impact Assessment
DPA	Data Processing Agreement
DSAR	Data Subject Access Request
API GW	API Gateway
LB	Load Balancer
ALB	Application Load Balancer
NLB	Network Load Balancer
CDN	Content Delivery Network
Redis	Remote Dictionary Server
SQL	Structured Query Language
NoSQL	Not Only SQL
ACID	Atomicity, Consistency, Isolation, Durability
ETL	Extract, Transform, Load
ELT	Extract, Load, Transform
BI	Business Intelligence
OLTP	Online Transaction Processing
OLAP	Online Analytical Processing
AI	Artificial Intelligence
ML	Machine Learning
NLP	Natural Language Processing
OCR	Optical Character Recognition
LLM	Large Language Model
RAG	Retrieval-Augmented Generation
NLU	Natural Language Understanding
ANN	Approximate Nearest Neighbor
SaaS	Software as a Service
PaaS	Platform as a Service
IaaS	Infrastructure as a Service

Acronym	Meaning
AWS	Amazon Web Services
GCP	Google Cloud Platform
OCI	Oracle Cloud Infrastructure
CDN	Content Delivery Network
Docker	Containerization Platform
K8s	Kubernetes
ECS	Elastic Container Service
EKS	Elastic Kubernetes Service
GKE	Google Kubernetes Engine
IAM	Identity and Access Management
KMS	Key Management Service
HSM	Hardware Security Module
S3	Simple Storage Service
CDN	Content Delivery Network
AZ	Availability Zone
MVC	Model-View-Controller
SSR	Server-Side Rendering
CSR	Client-Side Rendering
SEO	Search Engine Optimization
NPM	Node Package Manager
PHP	PHP: Hypertext Preprocessor
PSR	PHP Standards Recommendation
CLI	Command-Line Interface
SDK	Software Development Kit
IDE	Integrated Development Environment
Git	Distributed Version Control System
RBAC	Role-Based Access Control
SLA	Service Level Agreement
KPI	Key Performance Indicator